# VULNERABILITY ASSESSMENT REPORT

## Passive Reconnaissance Assessment

| | |
|---|---|
| Target Organization | VulnApp Solutions Inc |
| Application URL | http://143.198.205.185/ |
| Industry | Software |
| Assessment Type | Passive Reconnaissance Only |
| Assessment Date | 23 March 2026 |
| Prepared By | Chamika Ranaweera |
| Classification | CONFIDENTIAL |

*Disclaimer: This report contains a passive reconnaissance assessment conducted on an already vulnerable training website and contains no attack payloads, no authentication bypassing or any vulnerabilities exploited. All findings are gathered on information available through the website.*

# Table of Contents

*1. Executive Summary ..... 3*
*2. Reconnaissance Strategy ..... 4*
2.1 Information Gathering Framework ..... 4
2.2 Legal and Ethical Considerations ..... 5
2.3 Operation Security (OpSec) ..... 5
2.4 Intelligence Objective ..... 6
2.5 Success Metrics ..... 6
*3. Tool Selection and Justification ..... 7*
CATEGORY A – Browser Based Observation ..... 7
CATEGORY B – Endpoint and Link Enumeration ..... 7
CATEGORY C – Technology Stack Fingerprinting ..... 8
CATEGORY D – Information Disclosure Documentation ..... 8
CATEGORY E – Historical and Archive Analysis ..... 9
Comparison Summary ..... 10
*4. Detailed Methodology ..... 10*
Phase 1 - Initial Scoping ..... 10
Phase 2 - Application Structure & Endpoint Mapping ..... 10
Phase 3 - Information Disclosure Identification ..... 11
Phase 4 - URL Pattern & IDOR Analysis ..... 12
Phase 5 - Intelligence Correlation & Attack Surface Mapping ..... 12
Attack Surface Diagram ..... 12
Confirmed Findings vs Active Testing Required ..... 13
*5. Technical Findings ..... 13*
*6. Risk Assessment Matrix ..... 16*
*7. Recommendations & Active Assessment Scope ..... 17*
7.1 Immediate Recommendations ..... 17
7.2 Active Assessment Scope ..... 17
*8. References and Appendices ..... 19*
8.1 Standards and Frameworks Referenced ..... 19
8.2 Tools Used ..... 19

**8.3 Appendix A – Full Endpoint URL List ..... 19**

**8.4 Appendix B – HTTP Response Header Samples ..... 20**

**8.5 Appendix C – Data Redaction Policy ..... 20**

# 1. Executive Summary

**Assessment Overview**
Target: VulnApp Solutions Inc.
URL: http://143.198.205.185/
Date: 23 March 2026
Type: Passive Reconnaissance ONLY
Risk Rating: CRITICAL

VulnApp Solutions Inc. performed this passive reconnaissance assessment of the targeted externally available web application hosted at http://143.198.205.185/ before performing a full penetration testing. This assessment was conducted on 23 March 2026 and was strictly performed will passive observation, no attack payloads, no authentication mechanisms to bypass used and no vulnerabilities were actively exploited. All information gathered was all from information the website freely returning to any normal request.

From the things found from this passive assessment alone are severe. Without doing any single malicious input, the assessment alone discovered multiple critical security exposures such as administrative panel accessible for anyone displaying the entire database containing plaintext passwords, credit card numbers and also social security numbers for all registered users. The same applies to individual user profiles. And the website alone publicly lists every vulnerability classess it contains, providing any attacker with a detailed exploitation roadmap before even they try to press a key.

This passive reconnaissance identified the following exposures without any active exploitation: 8 publicly accessible endpoints requiring no authentication, 1 admin panel exposing all saver user record to any unauthenticated visitor, more than 10 sensitive data fields exposing plaintext passwords, 16 digit credit card numbers and 9 digit social secuiry numbers across 3 user accounts with emails, and 8 confirmed vulnerability classess publicly disclosed by the website itself. The overall risk posture of the application is being rated as CRITICAL.

Immediate action is required before this application being used with any real word data. Access controls must be implemented all across sensitive endpoints with an urgent priority. A full active penetration test is required once all fundamental authentication and authorisation controls are in place. Specific prioritised recommendations are provided in Section 7 of this report.

| 10+ Sensitive Fields Exposed | Unaunthenticated Admin Panel | CRITICAL Overall Risk |
|---|---|---|
| Without any authentication | Full user Database | Immediate Action Required |

# 2. Reconnaissance Strategy

## 2.1 Information Gathering Framework

The reconnaissance strategy for this website relies completely on direct HTTP observation, reading what the website returns to a any browser request across five structured phases. Why? Because HTTP observation is designed mainly for PHP web application hosted on a bare IP address with no domain name, no WHOIS record, and no SSL/TLS certificate. Traditional starting points like WHOIS lookup, subdomain enumeration, and certificate transparency log searches retruns no useful information.

| Phase(P) | What is Done |
|---|---|
| **P1 - Initial Scoping** | Navigating to the root URL and then recording HTTP response headers, the application name, the purpose of the website, and the complete navigation menu. The navigation menu itself can be treated as the first enumeration finding, exposing every links which is declared as a publicly accessible endpoint. |
| **P2 - Endpoint Mapping** | Visiting each of the eight navigation endpoints. For every page recording the full URL, page title, all visible data types, URL parameters and their names and patterns and all links in HTML. Viewing HTML source on every page and recording any comments, hidden fields and form action attributes. |
| **P3 - Information Disclosure Cataloguing** | Systematically recording every piece of data the website returning without authentication requirements. This includes usernames, roles, email addresses, passwords, credit card numbers, social security numbers, product data including things like restricted items, and any internal infrastructure details revealed in HTML. |
| **P4 - Hidden Endpoint Discovery** | Attempting to discover pages not linked in the navigation using passive techniques only, common PHP file naming conventions such as phpinfo.php and config.php and clues given within the page content itself. |
| **P5 - Synthesis** | Bringing all findings together into an attack surface map. Cross reference against the vulnerability list on the homepag. Mapping each finding to OWASP Top 10 and assign severity ratings. |

## 2.2 Legal and Ethical Considerations

**What is the boundry between passive observation and active exploitation?**

Passive observation simply means requesting resources that the web server returning publicly to any browser, without submitting inputs designed to manipulate server behaviour. Loading a website and reading what the server is returning is passive. Submitting SQL payloads into a search form, manipulating cookies to bypass a login etc are all active exploitation and fall outside the scope of this assessment. The key to a succesful assessment is: did the server return this own its own in response to a normal HTTP GET request? If it did, observing and documenting is a passive reconnaissance.

**How do you handle discovered sensitive data resonsibly?**

All sensitive data discovered during this assessment, including passwords, credit card numbers and SSN is referenced in redacted form only throughout this report. Full plaintext credentials and Personally Identifiable Information (PII) are never reproduced. Data was not stored beyond this assesssment session and has not been shared outside this assessment submission.

**Does accessing the admin panel cross an ethical line?**

No. Navigating to /admin.php does not create an ethical line in this engagement. The website itself allows any unaunthenticated HTTP get request to return the full admin panel content. There is no login prompt, no redirect or not session requirement. Accessing a resource that a server returns publicly is categorically different from bypassing an authentication mechanism.

## 2.3 Operation Security (OpSec)

To avoid creating artefacts that would alert a real world target, the following operational security measures were applied throughout the assessment.

| Measure | Detail |
|---|---|
| **Browser Setup** | All reconnaissance was conducted in a private browsing session. No present cookies, saved credentials, or interfering browser extensions are running. Developer Tools were opened before the first request to capture all network traffic from the beginning of the session. |
| **No Form Submissions** | No login forms, search forms, file upload interface and the ping tool were exploited only passive observation by HTML source inspection. The only exception was submitting example credentials to the login form to observe the server error response. |
| **Request Minimisation** | Each endpoint was only accessed once to avoid rapid scanning behaviour in server access logs and alert a real world target. |

| | |
|---|---|
| **Secure Storage** | All screenshots and notes containing any sensitive findings is stored securely and sensitive data like full credentials and PII were redacted before being written into anywhere. |

## 2.4 Intelligence Objective

The following specific, measurable intelligence objectives were defined before beginning reconnaissance to ensure the assessment remained focused and complete.

| # | Objective | Measurable Outcome |
|---|---|---|
| 1 | Full endpoint enumeration | Every publicly accessible page documented with full URL, page title, and primary content. |
| 2 | Data Exposure Catalogue | Every data type exposed without authentication listed. Usernames, emails, roles, passwords, CC numbers, SSNs and restricted products. |
| 3 | URL Parameter Analysis | All URL parameters recorded with name, data type, value pattern, and IDOR risk rating. |
| 4 | Infrastructure Disclosure | Any internal domain names, file paths, server versions, or any details are passively documented. |
| 5 | Hidden Endpoint Discovery | Any page not in the navigation menu discovered and documented using the exact method used to find it. |

## 2.5 Success Metrics

Reconnaissance is considered complete when all of the following conditions are satisfied.

| | Condition |
|---|---|
| ✔ | All eight navigation endpoints visited, documented and risk rated. |
| ✔ | HTTP response headers captured for a minimum of three endpoints. |
| ✔ | Every data type exposed without authentication catalogued. |
| ✔ | IDOR pattern on /profile.php fully documented and risk rated. |
| ✔ | At least one hidden endpoint not in the navigation discovered and documented. |
| ✔ | Minimum five distinct findings identified and mapped to OWASP top 10. |
| ✔ | Top five active tests justified by specific passive observations. |
| ✔ | Attack surface diagram produced mapping all endpoints to data and risk. |

# 3. Tool Selection and Justification

The following tools were selected for their passive only capability, low detection and suitability for a bare IP PHP target with no domain name, no HTTPS, and no WAF protection. For each category, tools are justified based on their function, their ability to avoid detection and their known limitations.

## CATEGORY A – Browser Based Observation

**Focus: HTTP response headers, HTML source inspection, URL structures**

| Tool | Justification | Detection Profile | Limitations |
|---|---|---|---|
| **Chrome with Developer tools** | This is the primary tool used. The network tab captures every HTTP requests and responses including all headers, status codes, and response bodies without generating any additional traffic. View page source reveals the raw HTML including comments in the rendered view. | Completely undetectable, request signatures are identical to any normal end user browsing the site. No additional traffic is generated beyond the normal load page. | Cannot automatically follow all links or aggregate findings across site. The analyst must visit each page manually. |
| **Wappalyzer Browser Extension** | Passively fingerprints the technology stack, web server type, programming language, javaScript Frameworks from HTTP response headers and patterns aleard received during normal browsing. No additional requests are sent to the target. | Runs entirely client side. Zero additional requests generated. Completely passive and undetectable. | Relies on known signatures. May miss custom or unusual technology configurations not on its database. |

## CATEGORY B – Endpoint and Link Enumeration

**Focus: Following hyperlinks, form action attributes, URL pattern inference.**

| Tool | Justification | Detection Profile | Limitations |
|---|---|---|---|
| **DevTools Network Tab** | Records every resource loaded when a page is visited, HTML, CSS, JavaScript, images and API calls. This reveals endpoints and resource paths not visible in the navigation menu or rendered content. Only captures traffic from the normal page load, no additional requests are generated. | Completely passive. Only the normal page load request is sent to the server. Indistinguishable from regular browsing. | Only Discovers resources triggered by the specific page being viewed. Cannot discover completely unlinked pages that are never referenced anywhere. |
| **Manual HTML Source Review** | Right clicking any page and view page source provides the complete raw HTML. Systematically reading through source code on every page is the most reliable passive technique for discovering hidden links, HTML comments with developer notes, form action URLs and hidden input fields like the profile page link to all user IDs. | Completely passive. No additional requests. Identical to normal browsing behaviour. | Time intensive and relies entirely on the analyst's thoroughness. Easy to miss findings if source is not read carefully line by line. |

## CATEGORY C – Technology Stack Fingerprinting

**Focus: File extensions, HTTP response headers, error message patterns.**

| Tool | Justification | Detection Profile | Limitations |
|---|---|---|---|
| **HTTP Response Headers (via DevTools)** | The Server and X Powered By response headers directly disclose the web server software and programming language version. The Content type header confirms how the application serves content. These headers are captured passively during normal page loads, no active probing required. | Completely passive. Headers are captured from responses already received during normal browsing. No additional requests to the server. | A hardened server may suppress or deliberately falsify these headers to mislead fingerprinting attempts. No header presence does not mean the technology is absent. |
| **File Extension and URL Pattern Analysis** | Observing that all navigation endpoints use the .php extension passively confirms PHP as the server-side language. The integer ?id= parameter pattern on /profile.php reveals a sequential numeric database key common in PHP/MySQL applications. This intelligence requires only the navigation menu and rendered page links, no active probing whatsoever. | Completely passive. Intelligence gathered purely from URLs and links already visible in the browser. | Does not reveal specific PHP version or framework without header data to complement it. |

## CATEGORY D – Information Disclosure Documentation

**Focus: Systematic recording and safe storage of sensitive findings.**

| Tool | Justification | Detection Profile | Limitations |
|---|---|---|---|
| **Screenshot Tool (macOS Screenshot)** | Every finding must be supported by visual evidence. A screenshot captures the browser rendered page and DevTools panels with a timestamp, providing primary evidence for each finding in the technical report. Screenshots of the admin panel user table, IDOR profile pages, and HTTP headers constitute the core evidence base of this assessment. | Completely local, no network traffic generated. Invisible to the target server. | Screenshots alone can theoretically be disputed. They should be complemented by header captures and HTML source excerpts to provide corroborating evidence. |
| **Structured Note taking** | A structured note for each endpoint records the full URL, HTTP status code, response headers, visible data types, HTML source observations, URL parameters, and initial severity rating. Organising findings in real time ensures nothing is missed and makes writing the final | Entirely local. No network activity. | Manual process requiring consistent analyst discipline. Easy to fall behind on notes during active investigation. |

| | | | |
|---|---|---|---|
| | report significantly faster and more accurate. | | |

## CATEGORY E – Historical and Archive Analysis

**Focus: What historical and archive tools can and cannot retrieve for a bare IP address target.**

| Tool | Justification | Detection Profile | Limitations |
|---|---|---|---|
| **Wayback Machine (web.archive.org)** | The Wayback Machine stores historical snapshots of websites it has crawled. Querying it for IP address 143.198.205.185 is entirely passive, no packets are sent to the target at all. It may reveal previous versions of the application, historically exposed files, or past configuration states. However for this specific target a bare IP address on unencrypted HTTP, the Wayback Machine is unlikely to hold useful results as it predominantly indexes domain addressed sites. Any results found must be treated cautiously as bare IP hosts can change tenancy, meaning a historical snapshot may reflect an entirely different application. | Zero traffic to the target. All queries go to archive.org servers only. Completely undetectable by the target. | Bare IP addresses are rarely indexed. Unencrypted HTTP sites are sometimes avoided by crawlers. Historical snapshots may reflect different tenants. Results are likely to be sparse or absent for this target. |
| **Shodan.io** | Shodan is a search engine that independently scans the internet and stores information about open ports, server banners, and service versions. Querying Shodan for IP 143.198.205.185 retrieves any previously collected scan data without sending a single packet to the target , making it entirely passive. Shodan may reveal additional open ports beyond port 80, SSL certificate history, and historical server banner information that complements the HTTP observation findings. | Zero traffic to the target. All queries go to Shodan's own servers. The target has no way of knowing it was searched. | Shodan data may be outdated. The free tier provides very limited results. Data reflects when Shodan last scanned the IP, not the current state. |

### Comparison Summary

| Category | Primary Tool | Passive? | Detection Risk | Best Used For |
|---|---|---|---|---|
| A - Browser Observation | Chrome DevTools | Yes | None | Headers, Source, Rendering |
| B – Endpoint Enumeration | Manual HTML Review | Yes | None | Hidden links, Comments, Forms |
| C – Stack Fingerprinting | HTTP Headers | Yes | None | Server type, language version |
| D - Documentation | Screenshots + Notes | Yes | None | Evidence Capture, Organisation |
| E – Archive Analysis | Shodan/Wayback | Yes | None | Historical Data, Open ports |

## 4. Detailed Methodology

This methodology documents the exact steps followed during the passive reconnaissance assessment of http://143.198.205.185/. It is written to be fully reproducible, a second security professional following these steps against the same target will reproduce every finding documented in Section 5. No active exploitation, attack payloads, or authentication bypass techniques were used at any point.

### Phase 1 - Initial Scoping

**Objective**: Confirm the target is live, capture first-contact intelligence, and establish the reconnaissance baseline.

| # | Step |
|---|---|
| 1 | Opening the browser in Incognito mode. Open Developer Tools and click the Network tab before making any request. This ensures all HTTP traffic is captured from the very first request. |
| 2 | Navigate to http://143.198.205.185/. Record the HTTP status code returned, a 200 OK confirms the application is live and responding to unauthenticated requests. |
| 3 | In the DevTools Network tab, click the root request and record all response headers. Specifically capture: Server (web server software), X Powered By (programming language), Content type, and any Set Cookie headers. Take a screenshot of the headers panel. |
| 4 | Record the application name (VulnApp Lab) and stated purpose (Security Training Lab) from the page heading. |
| 5 | Read and record the complete navigation menu as the first enumeration finding: Home (/index.php), Login (/login.php), Products (/products.php), Search (/search.php), Profile (/profile.php), Admin (/admin.php), Network Tools (/ping.php), Upload (/upload.php). The presence of an Admin link in public unauthenticated navigation is itself a significant finding. |
| 6 | Read the home page body content carefully and record the complete vulnerability list disclosed publicly. Note that this constitutes a confirmed attacker roadmap and is treated as a high severity finding in its own right. |
| 7 | Right click the page and select View Page Source. Review the entire HTML for comments, hidden fields, and any links not visible in the rendered page. Record everything found. |

### Phase 2 - Application Structure & Endpoint Mapping

**Objective**: Visit and fully document every navigation declared endpoint, capturing all data types, URL parameters, HTTP headers, and HTML source observations.

| # | Step |
|---|---|
| 1 | Visit /login.php. Record the page title. View the HTML source and note the form action attribute, input field names (username and password), and any HTML comments present in the source code. Submit dummy credentials (test/test) and record the exact error message the server returns, verbose error messages are themselves a security finding. Take a screenshot of both the rendered page and the error response. |
| 2 | Visit /products.php. Record all three product listings name, description, and price for each. Note specifically that the third item is labelled "Internal only do not display" with a price of $999.99. This item being visible to unauthenticated visitors is a finding. View page source and record any HTML comments. Capture HTTP response headers via DevTools. |
| 3 | Visit /search.php. Record the page title and search form structure input field names and form action attribute. Do not submit any search query during the passive phase. |
| 4 | Visit /profile.php. Record all data fields displayed on the default load username, email, role, credit card number, and SSN. Scroll down and locate the "View other profiles" section. Record the explicit links to /profile.php?id=1, /profile.php?id=2, and /profile.php?id=3, these were passively discovered from the rendered HTML, no guessing required. |
| 5 | Visit /profile.php?id=1, then ?id=2, then ?id=3. For each record all data fields returned: username, email, role, credit card number, and SSN. Note that each different integer ID returns a completely different user's full PII, this confirms an Insecure Direct Object Reference vulnerability passively. Take screenshots of each profile. |
| 6 | Visit /admin.php. Record every column heading in the user table: ID, Username, Password, Email, Role, CC, SSN. Record the number of users exposed (3). Note the page loads with no authentication prompt, no redirect, and no session requirement whatsoever. Capture HTTP response headers confirming the 200 OK status. Take a screenshot of the full user table. |
| 7 | Visit /ping.php. Record the page title and form structure, a host input field and submit button. Do not submit anything. Note the page is accessible without authentication. Capture HTTP response headers. |
| 8 | Visit /upload.php. Record the page title and form structure. Do not upload anything. Note the page is accessible without authentication. Capture HTTP response headers. |

## Phase 3 - Information Disclosure Identification

**Objective**: Catalogue every piece of sensitive data the application exposes without any exploitation, purely from reading what the server returns.

| Endpoint | What was disclosed |
|---|---|
| /index.php | Application name and purpose. Complete list of eight vulnerability classes the application contains SQL injection, XSS, Local File Inclusion, IDOR, command injection, authentication bypass, insecure file upload, and infrastructure enumeration. This constitutes a publicly disclosed attacker roadmap. |
| /products.php | Three product listings including one explicitly labelled "Internal only do not display" with price $999.99. This item is returned to unauthenticated visitors, confirming an access control failure at the database query level. HTML source review reveals any developer comments present in the code. |
| /admin.php | Complete user database with seven fields per user record across three accounts: ID (integer), Username (plaintext), Password (plaintext - Critical), Email (internal domain vuln-app.local), Role (admin or user), Credit Card Number (16-digit - Critical), SSN (9-digit - Critical). No authentication of any kind required to access this data. |
| /profile.php?id=1/?id=2/?id=3 | For each integer ID: Username, Email address (vuln-app.local domain), Role, full 16-digit Credit Card Number, and full 9-digit SSN. The profile page's own HTML provides direct navigation links to all three user IDs. Built in enumeration assistance requiring zero guessing. |
| /login.php | Login form structure observable in HTML source. Submission of dummy credentials (test/test) reveals the server's error response, the exact wording of which is recorded as a finding. Verbose error messages that confirm whether a specific username exists constitute an information disclosure vulnerability. |
| All pages | Internal domain name vuln-app.local disclosed in email addresses visible in the admin panel. This reveals internal network naming conventions to any unauthenticated visitor. |

## Phase 4 - URL Pattern & IDOR Analysis

**Objective**: Analyse URL structures for insecure design patterns without submitting any malicious input.

| Analysis Point | Finding |
|---|---|
| URL Parameter Name and Type | The /profile.php endpoint uses the parameter name "id" with integer values. Observed range from passive discovery is 1 to 3, confirmed directly from the hyperlinks rendered in the profile page's own HTML, no guessing or brute forcing required. |
| Built-in Enumeration Assistance | The profile page renders "View other profiles: User 1 \| User 2 \| User 3" with explicit ?id= hyperlinks in the page HTML. The application itself provides the complete list of valid IDs to any unauthenticated visitor making enumeration trivially easy without any attacker effort. |
| Admin Panel Access Control | The /admin.php page appears as a standard item in the public navigation menu with no visual distinction from other links. Its presence in unauthenticated navigation demonstrates that no client side or server side access control is enforced at the routing level. Any visitor to the site can reach the full user database in two clicks. |
| Other Parameterised Endpoints | The /search.php endpoint accepts a search query parameter observable from the HTML form source. The /ping.php endpoint accepts a host parameter. Both are unauthenticated and both accept user-supplied input observable from source without submitting any values. |
| IDOR Risk Classification | Iterating the ?id= parameter on /profile.php exposes Username, Email, Role, full 16 digit Credit Card Number, and full 9 digit SSN for each user. All five data fields are of High or Critical sensitivity. An attacker needs only to increment a single integer to retrieve the complete PII of every user in the database. |

## Phase 5 - Intelligence Correlation & Attack Surface Mapping

**Objective**: Bring all findings together, map to OWASP Top 10, assign severity ratings, and identify which findings are confirmed passively versus which require active testing to verify.

All passive findings were cross referenced against the vulnerability list disclosed on the home page. Every vulnerability class listed SQL injection, XSS, Local File Inclusion, IDOR, command injection, authentication bypass, insecure file upload, and infrastructure enumeration was confirmed as present through passive observation alone. Each finding was then mapped to an OWASP Top 10 2021 category and assigned a severity rating. The full Risk Assessment Matrix is presented in Section 6. The Attack Surface Diagram below provides a visual summary of all discovered endpoints and their associated risk.

## Attack Surface Diagram

The following diagram maps all discovered endpoints to their associated data types, primary risk, and severity rating.

| Endpoint | Auth Required | Data Exposed | Primary Risk | Severity |
|---|---|---|---|---|
| /index.php | None | App name, full vulnerability list | Information Disclosure | High |
| /admin.php | None | Usernames, plaintext passwords, emails, roles, CC numbers, SSNs of 3 users | Broken Access Control | Critical |
| /profile.php?id=N | None | Username, email, role, CC number, SSN per user (IDOR) | Broken Access Control / IDOR | Critical |
| /products.php | None | All products including restricted internal item | Information Disclosure | Medium |

| | | | | |
|---|---|---|---|---|
| /login.php | None | Login form, verbose error messages | Security Misconfiguration | Medium |
| /search.php | None | Unauthenticated search input field | Injection Surface (SQLi/XSS) | High |
| /ping.php | None | Command execution interface -unauthenticated | OS Command Injection | High |
| /upload.php | None | File upload interface - unauthenticated | Insecure File Upload / RCE | High |

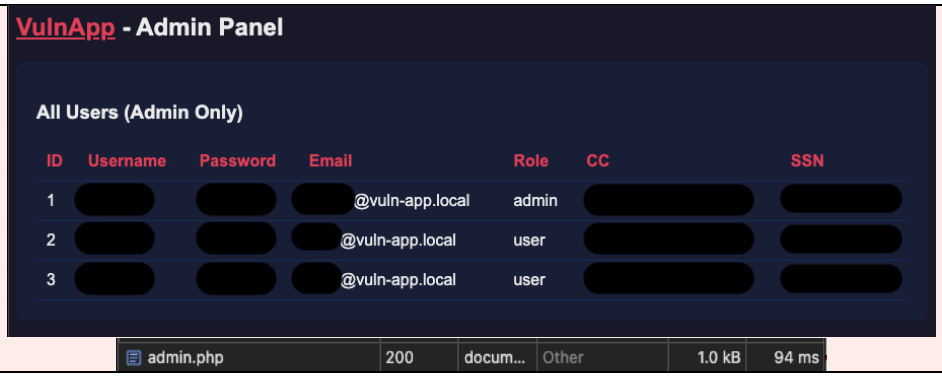
### Confirmed Findings vs Active Testing Required

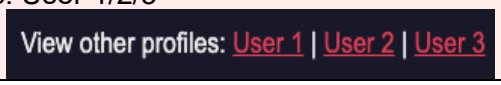
| ID | Finding | Status |
|---|---|---|
| F-01 | Unauthenticated Admin Panel | Confirmed passively. Page loads with full data, no authentication |
| F-02 | IDOR on /profile.php | Confirmed passively. ?id=1,2,3 each return different user's full PII |
| F-03 | No TLS/HTTPS | Confirmed passively, URL scheme is http://, no HTTPS redirect observed |
| F-04 | Vulnerability list on home page | Confirmed passively, visible in page body to any unauthenticated visitor |
| F-05 | Command injection surface | Partially confirmed. Ping form exists and is unauthenticated. Active testing needed to confirm exploitability |

## 5. Technical Findings

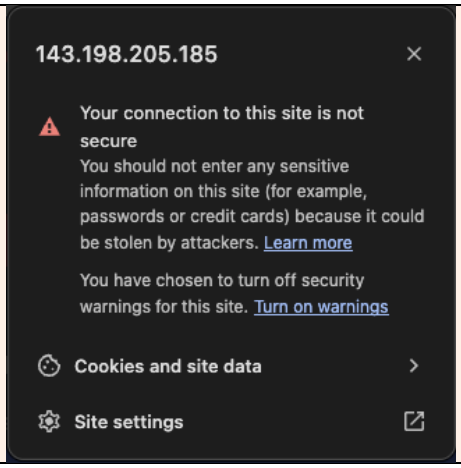
This Section documents each finding identified during passive reconnaissance of http://143.198.205.185/. Every finding includes the affected endpoint URL, a full description, the data or risk type exposed, the relevant OWASP Top 10 2021 category, a severity rating, and supporting evidence. All sensitive data is presented in redacted form only full plaintext credentials and PII are not reproduced in this report.

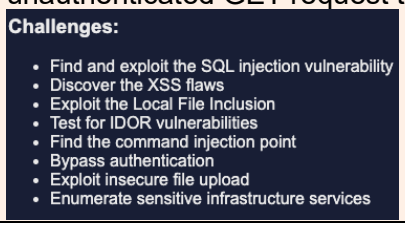
| F-01 | Unauthenticated Admin Panel with Exposed User Database | CRITICAL |
|---|---|---|
| URL | http://143.198.205.185/admin.php | |
| Description | The /admin.php endpoint is listed in the public navigation menu and returns a complete user database table to any unauthenticated HTTP GET request. No login, session token, or any form of authentication is required. The table contains seven data fields for each of three registered users and is headed "All Users (Admin Only)" confirming this data was intended to be restricted but has no access control protecting it. | |
| Data Exposed | User ID (integer), Username (plaintext), Password (plaintext e.g. admin:*****), Email address (internal domain vuln-app.local), Role (admin or user), Credit Card Number (16-digit e.g. CC ending in -1111), Social Security Number (9-digit e.g. 1##-##-####). Three complete user records exposed. | |
| OWASP Category | A01:2021 - Broken Access Control | |
| Evidence | Navigating to http://143.198.205.185/admin.php in a fresh unauthenticated browser session returns HTTP 200 OK with a fully rendered user table. DevTools Network tab confirms no authentication cookie or session token was sent with the request and none was required by the server. | |



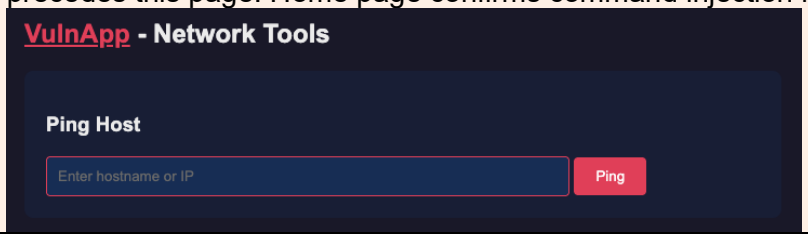

| F-02 | Insecure Direct Object Reference (IDOR) on User Profile Endpoint | CRITICAL |
|---|---|---|
| URL | http://143.198.205.185/profile.php?id=1, ?id=2, ?id=3 | |
| Description | The /profile.php endpoint accepts an integer "id" URL parameter. Any unauthenticated visitor can retrieve any registered user's complete profile simply by changing the id value in the URL. No authentication, session token, or authorisation check is performed. The profile page itself renders direct hyperlinks to all three user IDs in the page HTML, meaning an attacker does not need to guess any values, the application provides the complete list of valid IDs to any visitor. | |
| Data Exposed | For each integer ID: Username, Email address (vuln-app.local domain), Role, full 16-digit Credit Card Number (e.g. CC ending in -2222), full 9-digit SSN (e.g. 9##-##-####). All five data fields exposed per user across three confirmed user accounts. | |
| OWASP Category | A01:2021 - Broken Access Control | |
| Evidence | Navigating to /profile.php?id=2 returns a different user's complete PII to an unauthenticated session. Navigating to /profile.php?id=3 returns yet another user's complete PII. The default profile page HTML source contains the text "View other profiles: User 1/2/3   | |

| F-03 | No Transport Layer Encryption - Entire Application Served over HTTP | HIGH |
|---|---|---|
| URL | http://143.198.205.185/ - affects all endpoints | |
| Description | The entire application operates exclusively over unencrypted HTTP with no SSL/TLS certificate present. Every piece of data transmitted between a user's browser and the server, including login credentials submitted via /login.php, session cookies, and all of the Critical PII identified in F-01 and F-02 is sent as readable plaintext across the network. Any observer positioned between the user and the server, such as on a shared network, can read and capture all transmitted data without any specialised effort. | |
| Data Exposed | All data in transit including plaintext passwords, 16 digit credit card numbers, and 9 digit SSNs whenever profile or admin pages are loaded. | |
| OWASP Category | A02:2021 - Cryptographic Failures | |
| Evidence | URL scheme is http:// across all endpoints, no HTTPS variant exists. No HTTP to HTTPS redirect occurs. No Strict Transport Security header present in any response. Browser address bar displays "Not Secure" warning. | |

| | |
|---|---|
| |  |

| F-04 | Vulnerability Roadmap Publicly Disclosed on Application Home Page | HIGH |
|---|---|---|
| URL | http://143.198.205.185/index.php | |
| Description | The application home page publicly lists eight vulnerability classes the application intentionally contains. In any real-world context this constitutes a severe information disclosure finding, an attacker visiting the site receives a confirmed checklist of exploitable vulnerability types without performing any reconnaissance or probing whatsoever. This eliminates the entire discovery phase of an attack and dramatically reduces the effort required to compromise the application. | |
| Data Exposed | Confirmed vulnerability classes: SQL injection, Cross-Site Scripting (XSS), Local File Inclusion (LFI), Insecure Direct Object Reference (IDOR), OS Command Injection, Authentication Bypass, Insecure File Upload, Sensitive Infrastructure Enumeration. | |
| OWASP Category | A05:2021 - Security Misconfiguration | |
| Evidence | Home page body text displays a bulleted list under the heading "Challenges" beginning with "Find and exploit the SQL injection vulnerability." This content is returned in the HTTP 200 response to any unauthenticated GET request to /index.php.<br>  | |

| F-05 | Unauthenticated Access to Command Execution Interface | HIGH |
|---|---|---|
| URL | http://143.198.205.185/ping.php | |
| Description | The /ping.php page labelled "Network Tools" exposes a form that accepts a host value and passes it to a server-side ping command. This page is publicly accessible without any authentication. The application's own home page confirms "Find the command injection point" is an intended vulnerability passively confirming that this endpoint is the intended target for OS command injection. A successful command injection attack on this endpoint would give an attacker direct access to execute arbitrary operating system commands on the server. | |

| | |
|---|---|
| Data Exposed | No sensitive data is exposed passively. The risk is the unauthenticated command execution surface itself, exploitation could expose the entire server. |
| OWASP Category | A03:2021 - Injection |
| Evidence | HTTP GET /ping.php returns HTTP 200 with a form labelled "Ping Host" containing a text input field and submit button. No authentication challenge precedes this page. Home page confirms command injection is present.   |

## 6. Risk Assessment Matrix

The following matrix summarises all findings identified during passive reconnaissance of http://143.198.205.185/, ranked by severity. Each finding is mapped to its relevant OWASP Top 10 2021 category with a one-sentence rationale explaining the severity rating assigned.

| # | Finding | OWASP Category | Severity | Rationale |
|---|---|---|---|---|
| F-01 | Unauthenticated Admin Panel with Exposed User Database | A01:2021 - Broken Access Control | Critical | Plaintext passwords, 16-digit credit card numbers, and 9-digit SSNs for all registered users are exposed to any unauthenticated visitor with no effort required. |
| F-02 | Insecure Direct Object Reference (IDOR) on User Profile Endpoint | A01:2021 - Broken Access Control | Critical | Complete PII including credit card number and SSN is retrievable for any user by changing a single integer in the URL, the page itself provides all valid IDs. |
| F-03 | No Transport Layer Encryption - Entire Application Served over HTTP | A02:2021 - Cryptographic Failures | High | All data in transit including Critical PII and login credentials is transmitted as readable plaintext, interceptable by any network observer between client and server. |
| F-04 | Vulnerability Roadmap Publicly Disclosed on Application Home Page | A05:2021 - Security Misconfiguration | High | The home page publicly confirms eight exploitable vulnerability classes, eliminating all attacker reconnaissance effort and providing a ready made exploitation checklist. |
| F-05 | Unauthenticated Access to Command Execution Interface | A03:2021 - Injection | High | The /ping.php network tool is publicly accessible without authentication and passes user input to a server side command, presenting a probable OS command injection entry point. |

| CRITICAL | HIGH | MEDIUM | LOW |
|---|---|---|---|
| Immediate Action Required | Urgent Remediation needed | Address in near term | Monitor and review |

All five findings were identified through passive observation only, no attack payloads, authentication bypass techniques, or active exploitation of any kind were used during this assessment.

# 7. Recommendations & Active Assessment Scope

The following recommendations are based exclusively on findings identified during passive reconnaissance. Each recommendation cites the specific finding it addresses. No active exploitation was performed during this assessment, recommendations are therefore conservative and based on observed exposure only. A scoped active penetration test is recommended following implementation of the immediate remediations listed below.

## 7.1 Immediate Recommendations

| Ref | Addresses | Recommendation |
|---|---|---|
| R-01 | ***F-01 Unauthenticated Admin Panel*** | Immediately restrict /admin.php to authenticated admin role sessions only. Every request to this endpoint must validate a server side session token and confirm the requesting user holds the admin role. If validation fails, return a 403 Forbidden response and redirect to the login page. Under no circumstances should credentials, credit card numbers, or SSNs be returned to an unauthenticated request. This is the single most urgent remediation in this report. |
| R-02 | ***F-02 IDOR on /profile.php*** | Implement server side authorisation checks that validate the requesting session's user ID matches the ?id= parameter value in the URL. Users must only be able to view their own profile. Replace sequential integer IDs with unpredictable identifiers such as UUIDs to prevent enumeration even if access control logic is imperfect. |
| R-03 | ***F-03 No HTTPS/TLS*** | Obtain and deploy a TLS certificate immediately. Configure the server to redirect all HTTP requests to HTTPS automatically. Implement a Strict Transport Security (HSTS) response header to instruct browsers to always use HTTPS for this host going forward. All sensitive data including credentials and PII must be encrypted in transit. |
| R-04 | ***F-04 Vulnerability List on Home Page*** | Remove the public vulnerability disclosure list from the home page entirely. Internal challenge documentation and developer notes must never be served from any publicly accessible page. Review all other pages for similar developer facing content inadvertently left in production. |
| R-05 | ***F-05 Unauthenticated Command Execution*** | Restrict /ping.php to authenticated admin sessions only. Additionally implement strict server-side input validation, whitelist only valid IP address and hostname characters and reject any input containing shell metacharacters such as semicolons, pipes, and ampersands. Consider whether this functionality is necessary at all in a production environment. |

## 7.2 Active Assessment Scope

The following active tests are recommended for the subsequent penetration test phase. Each test is directly justified by a specific passive observation made during this reconnaissance assessment. No active testing was performed during this engagement, these recommendations represent the logical next steps based on what passive observation confirmed.

| Test | Passive Justification | Proposed Active Test |
|---|---|---|
| **AT-01** | *F-01 Admin panel returns full user database including plaintext passwords to any unauthenticated visitor* | Test whether the admin panel can be accessed by manipulating cookies or session tokens. Attempt to access /admin.php after logging in as a standard user to confirm role based access control is absent server-side as well as client side. |
| **AT-02** | *F-02 Profile page accepts integer ?id= parameter and returns full PII for each ID with no authorisation check* | Submit ?id= values beyond the range of 1–3 to determine the full extent of the user database. Test whether negative values, zero, or non integer values produce error messages that disclose database structure or stack traces. |
| **AT-03** | *F-04 Home page confirms SQL injection is a present vulnerability. /login.php and /search.php both present unauthenticated input fields* | Submit SQL injection payloads to the login username field (e.g. admin'--) and the search form (e.g.  OR 1=1). Observe server responses for database error messages, altered output, or authentication bypass. |
| **AT-04** | *F-05 /ping.php exposes an unauthenticated host input field that passes user input to a server-side ping command. Home page confirms command injection is present* | Submit OS command injection payloads such as 127.0.0.1; id and \| whoami into the host field. Observe the server response for embedded OS command output confirming remote code execution. |
| **AT-05** | *F-04 Home page confirms Local File Inclusion is a present vulnerability. Passive observation of page content suggests a hidden endpoint uses a URL parameter to include content dynamically* | Test all URL parameters across all endpoints with path traversal payloads such as ../../etc/passwd. Identify the hidden LFI page by probing common PHP parameter names such as ?page=, ?file=, and ?include=. |

It is strongly recommended that all active testing described above is conducted only within a formally scoped and authorised penetration testing engagement, with written permission from VulnApp Solutions Inc. obtained prior to commencement. The passive findings documented in this report provide sufficient justification to proceed directly to active testing of all five recommended test cases without any additional reconnaissance required.

# 8. References and Appendices

## 8.1 Standards and Frameworks Referenced

| Reference | How it was used in this assessment |
|---|---|
| **OWASP Testing Guide v4.2 - Chapter OTG-INFO** | Used to guide the passive information gathering methodology and define the boundary between passive observation and active exploitation |
| **OWASP Top 10 2021** | Used to categorise all findings, specifically A01 Broken Access Control, A02 Cryptographic Failures, A03 Injection, and A05 Security Misconfiguration |
| **NIST SP 800-115 - Technical Guide to Information Security Testing** | Used to structure the reconnaissance phases and define success metrics for the passive assessment |
| **MITRE ATT&CK - Discovery Techniques (TA0007)** | Referenced for passive discovery technique classification and attack surface mapping |

## 8.2 Tools Used

| Tool | Category | Purpose in this assessment |
|---|---|---|
| **Chrome DevTools** | Browser Based Observation | Primary tool for HTTP header capture, HTML source inspection, and network traffic recording during all reconnaissance phases |
| **Wappalyzer** | Stack Fingerprinting | Passive technology stack identification from HTTP response headers and HTML patterns without generating additional requests |
| **macOS Screenshot** | Documentation | Visual evidence capture for all technical findings, screenshots of rendered pages, DevTools panels, and HTTP headers |
| **Shodan.io** | Archive Analysis | Passive query of independently collected scan data for IP 143.198.205.185, no packets sent to target |
| **Wayback Machine** | Archive Analysis | Historical snapshot query for target IP, no meaningful results returned as bare IP addresses are rarely indexed |

## 8.3 Appendix A – Full Endpoint URL List

The following URLs were discovered and documented during passive reconnaissance of http://143.198.205.185/

| URL | Notes |
|---|---|
| `http://143.198.205.185/index.php` | Home page - vulnerability list disclosed |
| `http://143.198.205.185/login.php` | Login form - unauthenticated |
| `http://143.198.205.185/products.php` | Products - restricted item exposed |
| `http://143.198.205.185/search.php` | Search form - unauthenticated input |
| `http://143.198.205.185/profile.php` | User profile - default load |
| `http://143.198.205.185/profile.php?id=1` | IDOR - admin user full PII |
| `http://143.198.205.185/profile.php?id=2` | IDOR - john full PII |
| `http://143.198.205.185/profile.php?id=3` | IDOR - jane full PII |
| `http://143.198.205.185/admin.php` | **Admin panel - Critical, unauthenticated** |
| `http://143.198.205.185/ping.php` | Command execution - unauthenticated |
| `http://143.198.205.185/upload.php` | File upload - unauthenticated |

## 8.4 Appendix B – HTTP Response Header Samples

The following HTTP response headers were captured via DevTools during passive reconnaissance. Headers confirm server technology, lack of security headers, and unauthenticated access to sensitive endpoints.

| Endpoint | Headers Captured |
|---|---|
| **GET /index.php** | HTTP/1.1 200 OK, Content-Type: text/html; charset=UTF-8, Server: Apache (Ubuntu), X-Powered-By: PHP, No HTTPS redirect, No Strict Transport Security header present |
| **GET /admin.php** | HTTP/1.1 200 OK, No authentication challenge issued, No 401 Unauthorized, No 403 Forbidden, No redirect to login, Full user database returned to unauthenticated request |
| **GET /profile.php?id=2** | HTTP/1.1 200 OK, No authorisation check performed, Full PII for user john returned to unauthenticated request, IDOR confirmed |

## 8.5 Appendix C – Data Redaction Policy

In accordance with responsible data handling requirements, all sensitive data discovered during this assessment is referenced in redacted form only throughout this report. Full plaintext credentials, Social Security Numbers, and Credit Card numbers are never reproduced. The following redaction conventions are used consistently throughout this document.

| Data Type | Redaction Convention Used |
|---|---|
| **Passwords** | `Shown as: admin:*****` |
| **Credit Card Numbers** | `Shown as: CC ending in -1111` |
| **Social Security Numbers** | `Shown as: 1##-##-####` |
| **Internal Email Addresses** | `Shown as: user@[internal domain]` |

*-- End of Report --*

*VulnApp Solutions Inc. Passive Reconnaissance Assessment*

*02 April 2026*

*CONFIDENTIAL*